

WorkForcePro

API Testing Strategy

Employee & OJT Training API Test Approach

Document Type: API Test Strategy (Planned Approach)

Project: WorkForcePro

Version: 1.0

Prepared by: Puskar Adhikari

Role: Sr. QA Engineer

Submission Date: 2026-07-05

1. Introduction

1.1 Purpose

This document defines the proposed API testing strategy for the WorkForcePro Employee and OJT Training APIs. It documents the planned approach only — no executable API specification (OpenAPI/Swagger) or running environment was provided as part of the assignment, so this strategy is written to be directly executable once an environment and base URL are available, without requiring re-analysis of the requirements at that time.

1.2 Objectives

- Validate Employee Management API behavior: creation, retrieval, update, and deletion.
- Validate OJT Training workflow APIs: assignment, completion, and supervisor approval.
- Validate business rule enforcement at the API layer (e.g., unique email, approval gating, assignment prerequisites) independent of the UI.
- Validate error handling and response consistency — correct status codes, structured error bodies, and predictable field-level validation messages.
- Establish a validation script structure (status code, schema, required fields, business rules) that can be reused as living regression checks once the collection is executable.

2. Scope

2.1 In-Scope Endpoints

Method	Endpoint	Purpose
POST	/api/employees	Create a new employee record
GET	/api/employees/{id}	Retrieve a single employee record by ID
PUT	/api/employees/{id}	Update an existing employee record
DELETE	/api/employees/{id}	Delete an employee record
POST	/api/trainings/assign	Assign an OJT training module to an employee
POST	/api/trainings/complete	Mark an assigned training as completed by the employee
POST	/api/trainings/approve	Supervisor approves or rejects a completed training

2.2 Out of Scope

- Performance/load testing of API endpoints (recommend a dedicated performance pass before production scale-up).
- Penetration/security testing beyond basic authorization checks (recommend a dedicated security assessment).
- Any endpoints not listed in Section 2.1 (e.g., certifications, reporting) — not documented in the provided API list; flagged in Section 8 (Risks) as a coverage gap to confirm with the API owner.

3. Assumptions & Constraints

- APIs are REST-based and exchange JSON payloads.
- Standard HTTP status codes are used (200/201 success, 400 validation error, 401/403 auth error, 404 not found, 409 conflict).
- Authentication mechanism and exact request/response payload schemas were not specified in the assignment; this strategy assumes a bearer-token or session-based auth model, to be confirmed once the API is executable.
- Employee email is the field enforcing uniqueness (EMP-002), consistent with the functional test plan.
- Training status follows the lifecycle: Assigned → Pending Approval → Approved / Rejected, consistent with OJT-002/OJT-003.

Because no OpenAPI/Swagger definition or live environment was provided, every assumption above must be re-validated against the real API before the Postman collection is executed — see Section 8 (Risks & Limitations).

4. Test Approach / Methodology

4.1 Layered Validation

Each endpoint is tested independently of the UI, using the same layered technique applied in the functional test plan: positive path, negative path, and — where a business rule is boundary-sensitive — an edge case. This isolates whether a defect originates at the API/business-logic layer or the UI layer.

4.2 Chaining Strategy

Employee and training IDs generated by POST/assign calls are captured into Postman environment variables (e.g., {{employeeId}}, {{trainingId}}) and reused by subsequent requests in the same folder, so the collection can run end-to-end (create → assign → complete → approve) as well as in isolation per endpoint.

4.3 Design Techniques Applied

- Equivalence Partitioning — valid vs invalid field formats (e.g., malformed email).
- Negative / Error-Guessing — missing required fields, invalid foreign-key references (non-existent employee/training IDs).
- State Transition Testing — training status transitions validated via the approve/complete endpoints (e.g., approving a training that is not yet completed).
- Contract Testing — response structure and required fields checked on every call, not only status code, since a 200 with a malformed body is still a defect.

5. Planned Test Coverage

5.1 Positive Scenarios

ID	Endpoint	Scenario	Expected Result	Priority
API-TC-001	POST /api/employees	Create employee with valid, complete payload	201 Created; response body contains the new employee with a generated ID	High
API-TC-002	GET /api/employees/{id}	Retrieve an existing employee by valid ID	200 OK; response body matches the created employee	High
API-TC-003	PUT /api/employees/{id}	Update an existing employee with valid fields	200 OK; response reflects updated fields	High
API-TC-004	DELETE /api/employees/{id}	Delete an existing employee by valid ID	200/204; subsequent GET on the same ID returns 404	High
API-TC-005	POST /api/trainings/assign	Assign a valid training module to a valid employee	201 Created; assignment reflects status 'Assigned'	High
API-TC-006	POST /api/trainings/complete	Complete a training that is currently in 'Assigned' status	200 OK; status transitions to 'Pending Approval'	High
API-TC-007	POST /api/trainings/approve	Approve a training currently in 'Pending Approval' status	200 OK; status transitions to 'Approved'	High

5.2 Negative Scenarios

ID	Endpoint	Scenario	Expected Result	Priority
API-TC-008	POST /api/employees	Create employee using an email that already exists	409 Conflict (or 400); structured error identifying the duplicate email field	High
API-TC-009	POST /api/employees	Create employee with missing mandatory field(s) (e.g., Name or Email)	400 Bad Request; error body lists the missing/invalid field(s)	High
API-TC-010	GET /api/employees/{id}	Retrieve employee using a non-existent ID	404 Not Found; structured error body, not a raw stack trace	Medium
API-TC-011	PUT /api/employees/{id}	Update employee using a non-existent ID	404 Not Found	Medium
API-TC-012	DELETE /api/employees/{id}	Delete employee using a non-existent ID	404 Not Found	Low
API-TC-013	POST /api/trainings/assign	Assign training using a non-existent employee ID or training ID	400/404; clear error identifying which reference is invalid	High
API-TC-014	POST /api/trainings/complete	Complete a training that was never assigned to the employee	400/404; request rejected, no completion record created (validates OJT-004)	High
API-TC-015	POST /api/trainings/approve	Approve a training that is not yet in 'Pending Approval' status (e.g., still 'Assigned')	400/409; request rejected — approval cannot bypass the completion step (validates OJT-003)	High
API-TC-016	POST /api/trainings/approve	Attempt approval as a non-Supervisor role	401/403 Forbidden — role-based authorization enforced at the API layer	High

6. Validation Checklist

Applied to every request in the collection, positive or negative, so a passing status code alone is never treated as sufficient evidence of correctness.

Check	Description
Status Codes	Every response is checked against the expected HTTP status for that scenario (2xx for success, 4xx for client errors) — never assumed from the endpoint's 'happy path' alone.
Response Structure	Response body matches the expected JSON shape (correct keys, types, and nesting) using a schema or key-presence assertion, not just a manual glance.
Required Fields	Mandatory fields (e.g., employee email, training ID) are present and non-null in every successful response.
Business Rules	Domain rules are enforced server-side, not only in the UI — e.g., duplicate email rejected, approval blocked until completion, assignment blocked without a valid employee/training reference.
Error Messages	Error responses are structured and human-readable (field name + reason), not generic 500s or raw exception traces.
Response Time	Baseline response time is captured per endpoint (informational at this stage, not a hard SLA) to flag any endpoint that is disproportionately slow before a dedicated performance pass.
Authorization	Role-restricted actions (e.g., approve/reject) are rejected for unauthorized roles with 401/403, not silently allowed or returned as a 500.

7. Test Data Strategy

- Valid employee records — complete, correctly formatted fields, unique email per test run (e.g., timestamp-suffixed email to avoid collisions across repeated runs).
- Invalid employee records — missing mandatory fields, malformed email, duplicate email (reused deliberately from a prior valid record).
- Assigned vs. unassigned training data — at least one employee with an active 'Assigned' training and one with none, to exercise both OJT-002 (complete) and OJT-004 (cannot complete unassigned) paths.
- Pending-approval training data — a training already marked 'Completed' by the employee, used specifically to exercise the approve/reject endpoints without re-running the full chain each time.
- All test data is synthetic and created via the API itself at the start of each run (setup requests in Postman's Pre-request/Collection Runner flow), so the suite is self-contained and does not depend on manually seeded state.

8. Risks & Limitations

Risk Score = Probability × Impact (High/Medium/Low qualitative scale).

ID	Risk / Limitation	Probability	Impact	Score	Mitigation
R-1	No OpenAPI/Swagger definition or running API was provided	High	High	High	Payload/schema assumptions in Section 3 must be confirmed against the real API before first execution; treat this document as a strategy, not a validated collection, until then
R-2	Authentication mechanism is unspecified	Medium	High	High	Build the Postman collection with an Auth folder/variable placeholder ({{authToken}}) that can be swapped for the real mechanism (Bearer/session/API key) without restructuring requests
R-3	Exact response schemas are unknown	Medium	Medium	Medium	Write schema assertions as soon as one real response is observed; do not hardcode assumed field names into assertions ahead of time
R-4	Endpoints beyond Employees/Trainings (e.g., Certifications) are not documented in the API list	Low	Medium	Low	Confirm with the API owner whether Certification endpoints exist; if so, extend this strategy before the Postman collection is finalized

9. Recommended Postman Collection Structure

Organized so positive, negative, and environment setup are clearly separated — making it obvious at a glance what a failing run is actually testing.

- Environment — base URL, {{authToken}}, and chained variables ({{employeeId}}, {{trainingId}}) defined once and reused across all folders.
- Common Tests — shared Postman test scripts (status-code helper, response-time check, schema-shape helper) attached at the collection level so every request inherits them without duplication.
- Employees — API-TC-001 through API-TC-004 (positive) plus their corresponding negative variants, grouped by CRUD action (Create / Retrieve / Update / Delete).
- Trainings — API-TC-005 through API-TC-007 (positive), grouped by workflow stage (Assign / Complete / Approve).
- Negative Tests — a dedicated folder for API-TC-008 through API-TC-016, so the full negative suite can be run in isolation for regression without re-running the positive/happy-path chain.

9.1 Folder-to-Requirement Mapping

Postman Folder	Requirements Exercised
Environment	N/A — setup only
Common Tests	N/A — shared assertions
Employees	EMP-001, EMP-002
Trainings	OJT-001, OJT-002, OJT-003
Negative Tests	EMP-001, EMP-002, OJT-001, OJT-003, OJT-004

10. Traceability

Maps each functional requirement from the Master Test Plan to the API endpoint and API-level test case(s) that verify it independently of the UI.

Requirement ID	Requirement Description	Endpoint	API Test Case(s)
EMP-001	Users can create employee records	POST /api/employees	API-TC-001, API-TC-009
EMP-002	Employee email addresses must be unique	POST /api/employees	API-TC-008
OJT-001	Supervisors can assign OJT training modules	POST /api/trainings/assign	API-TC-005, API-TC-013
OJT-002	Employees can mark assigned training as completed	POST /api/trainings/complete	API-TC-006
OJT-003	Completed training requires supervisor approval	POST /api/trainings/approve	API-TC-007, API-TC-015, API-TC-016
OJT-004	Employees cannot complete unassigned training	POST /api/trainings/complete	API-TC-014

CRUD operations without a direct functional requirement in the assignment (PUT/DELETE /api/employees) are covered under general data-integrity expectations (API-TC-003, API-TC-004, API-TC-011, API-TC-012) rather than a named EMP/OJT requirement.

11. Deliverables

- This API Testing Strategy document.
- Postman Collection (.json) implementing the structure in Section 9, once the API environment is available.
- Postman Environment file (.json) with base URL and variable placeholders.
- Validation scripts embedded per request, per the checklist in Section 6.
- Test Report — coverage achieved, findings, and residual risk, generated after execution.

12. Sign-off

Role	Name	Signature / Date
Sr. QA Engineer	Puskar Adhikari	2026-07-05
QA Lead		